

Clase 320 — Gobierno, aspectos legales/regulatorios y gestión del programa

Parte: **17 — Profundización para certificaciones** · Fuente: (ISC)² CISSP Official Study Guide, 9.^a ed. (Dominio 1) · CompTIA Security+ (SY0-701) — Program Management 🕒 Duración estimada: **130 min** · Nivel: **Avanzado**

Objetivo

Cerrar el programa entendiendo cómo se **gobierna** la seguridad: alinear el programa con los objetivos del negocio, elegir **marcos** de control, cumplir **leyes y regulaciones**, y gestionar el programa con **políticas, roles, métricas y modelos de madurez**. Es el dominio 1 de CISSP y el bloque de *Program Management / Governance, Risk & Compliance* de Security+ —la capa que convierte controles técnicos aislados en un programa sostenible y auditable.

Resultados de aprendizaje

Al finalizar, el alumno podrá:

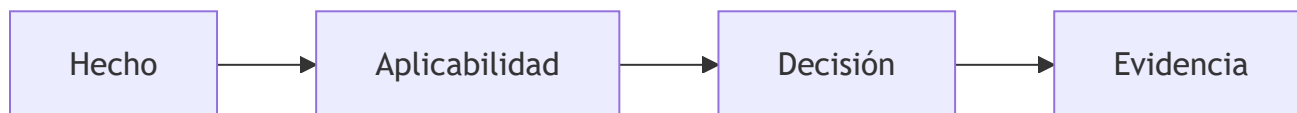
1. **Distinguir** gobierno, gestión y operación de seguridad, y ubicar el rol del CISO y del comité de riesgos.
2. **Comparar** marcos (NIST CSF, ISO/IEC 27001, NIST SP 800-53, CIS Controls, COBIT) y elegir según contexto.
3. **Mapear** obligaciones legales y regulatorias comunes (GDPR, HIPAA, PCI DSS, SOX, LGPD) a controles.
4. **Redactar** la jerarquía documental: política, estándar, procedimiento y guía (baseline).
5. **Medir** el programa con KPIs/KRIs y ubicarlo en un modelo de madurez.

Temas

#	Tema	Por qué importa
1	Gobierno vs gestión vs operación	Separa la dirección estratégica de la ejecución
2	Roles y responsabilidades (RACI, CISO, dueños de datos)	La rendición de cuentas evita vacíos
3	Marcos de seguridad	Estructura reconocida para construir y auditar el programa
4	Leyes y regulaciones	Cumplimiento obligatorio con consecuencias legales
5	Debida diligencia vs debido cuidado	Estándar legal de conducta razonable
6	Jerarquía documental	Convierte la estrategia en reglas ejecutables
7	Gestión de riesgos y apetito de riesgo	Prioriza inversión según tolerancia
8	Métricas y madurez (KPI/KRI, CMMI/NIST)	Demuestra valor y mejora continua

Modelo mental y caso de decisión

La obligación se determina por jurisdicción, entidad, dato y evento; el equipo técnico preserva hechos y coordina asesoría competente.



Caso razonado. Un plazo de notificación varía por régimen. Se evita prometer una regla universal y se activa la matriz jurídica.

Glosario operativo complementario

Término	Definición
Evidencia	Información cuya procedencia y relación con un criterio pueden revisarse.
Supuesto	Condición declarada de la que depende una conclusión.
Riesgo residual	Exposición que permanece después del tratamiento.

Criterio de dominio

El alumno demuestra dominio cuando explica el diagrama, resuelve el caso con evidencia, declara límites y puede defender por qué su decisión cambia si cambia un supuesto.

Definiciones y características

- **Gobierno de seguridad:** dirección estratégica que alinea la seguridad con los objetivos del negocio, define apetito de riesgo y asigna responsabilidad. Característica clave: responde *qué y por qué*, mientras la gestión responde *cómo*.
- **Debido cuidado (due care) y debida diligencia (due diligence):** *due care* es actuar como una persona prudente lo haría (implementar controles); *due diligence* es investigar y validar continuamente que se hace bien. Característica clave: reducen la responsabilidad legal por negligencia.
- **Marco de control:** estructura de referencia. **NIST CSF** (Identificar/Proteger/Detectar/Responder/Recuperar/Gobernar), **ISO/IEC 27001** (SGSI certificable), **NIST SP 800-53** (catálogo de controles), **CIS Controls** (priorizados y accionables), **COBIT** (gobierno de TI). Característica clave: no se compite, se combinan según necesidad y contexto regulatorio.
- **Política / estándar / procedimiento / guía:** la **política** es mandatoria y de alto nivel; el **estándar** fija requisitos obligatorios (p. ej. cifrado AES-256); el **procedimiento** son pasos operativos; la **guía (baseline/guideline)** es recomendación. Característica clave: jerarquía descendente de generalidad a especificidad.
- **Regulación vs marco:** una **regulación** (GDPR, HIPAA, PCI DSS, SOX, LGPD) es de cumplimiento **obligatorio** con sanciones; un marco es voluntario/estructural. Característica clave: el incumplimiento regulatorio tiene consecuencias legales/financieras.
- **Apetito y tolerancia al riesgo:** nivel de riesgo que la organización está dispuesta a aceptar para lograr objetivos. Característica clave: guía qué se remedia, transfiere, mitiga o acepta.
- **KPI vs KRI:** un **KPI** mide desempeño (p. ej. % de parches en SLA); un **KRI** es un indicador *anticipado* de riesgo (p. ej. nº de cuentas privilegiadas sin MFA). Característica clave: KPIs miran el pasado, KRIs anticipan problemas.
- **Modelo de madurez:** escala de capacidad del programa (p. ej. CMMI: Inicial → Gestionado → Definido → Cuantitativo → Optimizado). Característica clave: describe cómo de repetible y medible es el programa, no cuántos controles tiene.

Herramientas y preparación

Clase de GRC; el "entorno" es documental y de mapeo:

- **Plantillas de política** (SANS Security Policy Templates) como punto de partida —adáptalas, no las copies literalmente.
- **Hoja de cálculo** para el mapeo control ↔ marco ↔ regulación y para el RACI.
- **NIST CSF 2.0** y **CIS Controls v8** (descargables gratis) como marcos base.
- **Herramienta de diagrama** para el organigrama de gobierno y el flujo de aprobación de políticas.
- **Registro de riesgos (risk register)** en formato tabla: riesgo, dueño, probabilidad, impacto, tratamiento, estado.

Laboratorio guiado — Redactar una política y mapearla a marcos y regulación

Ejercicio aplicado: redactarás una política de seguridad de una organización ficticia y la conectarás con marcos, regulación y métricas.

1. **Define el contexto.** Elige una organización ficticia (p. ej. clínica que procesa datos de salud y pagos con tarjeta). Identifica qué regulaciones aplican (HIPAA por salud, PCI DSS por tarjetas, GDPR/LGPD si hay datos de la UE/Brasil).
2. **Establece el gobierno.** Dibuja el organigrama: junta directiva → CISO → equipos. Define un RACI para "aprobación de políticas" y "respuesta a incidentes".
3. **Redacta la política madre.** Una **Política de Seguridad de la Información** de alto nivel: propósito, alcance, roles, principios (CIA), cumplimiento y sanciones, y quién la aprueba/revisa (cadencia anual).
4. **Deriva la jerarquía.** Para un tema (p. ej. control de acceso), escribe: la **política** (declaración), un **estándar** (MFA obligatorio para accesos privilegiados), un **procedimiento** (pasos de alta/baja de cuentas) y una **guía** (recomendaciones de contraseñas).
5. **Elige un marco base.** Selecciona NIST CSF 2.0 o ISO 27001 y justifica por qué encaja con el contexto.
6. **Mapea controles.** En la hoja de cálculo, cruza: requisito de la política → función/control del marco (p. ej. CSF PR.AA) → requisito regulatorio (p. ej. PCI DSS 8.x, HIPAA §164.312). Marca cobertura y huecos.
7. **Construye el registro de riesgos.** Añade 5 riesgos con probabilidad × impacto, dueño y tratamiento (mitigar/transferir/aceptar/evitar), coherente con el apetito de riesgo declarado.
8. **Define métricas.** Elige 3 KPIs y 2 KRIs para reportar al comité, con umbral y frecuencia.
9. **Ubica la madurez.** Evalúa en qué nivel (CMMI 1–5) está cada capacidad y define una acción para subir un nivel.

Entregable: paquete con la política madre, la jerarquía documental de un tema, la matriz de mapeo marco↔regulación, el registro de riesgos y el cuadro de métricas.



Ejercicios

1. Clasifica cinco enunciados como política, estándar, procedimiento o guía y corrige los mal ubicados.
2. Mapea tres controles a NIST CSF 2.0 y al artículo/requisito correspondiente de una regulación.
3. Explica con un caso la diferencia entre due care y due diligence y cómo cada una reduce responsabilidad legal.
4. Diseña un RACI para el proceso de gestión de cambios de seguridad.
5. Define dos KRIs con umbral que anticipen un incidente de accesos.
6. Sitúa un programa descrito en un nivel CMMI y justifica el diagnóstico.



Reto verificable

Reto: entrega el paquete de gobierno de una organización ficticia: política madre + jerarquía documental de un dominio + matriz de mapeo (marco ↔ regulación) + registro de riesgos + cuadro de KPIs/KRIs.

Criterio de aceptación:

- La política madre incluye propósito, alcance, roles, cumplimiento, sanciones y cadencia de revisión con aprobador identificado.
- Se distinguen correctamente política, estándar, procedimiento y guía para el dominio elegido.
- El mapeo conecta cada requisito con un control de marco **y** un requisito regulatorio aplicable, señalando huecos.
- El registro de riesgos usa probabilidad × impacto, dueño y tratamiento coherente con el apetito de riesgo.

- Hay al menos 3 KPIs y 2 KRIs con umbral y frecuencia, más una evaluación de madurez con acción de mejora.

Errores comunes

Síntoma / mensaje	Causa y cómo arreglar
"Mi política tiene pasos operativos detallados"	Confusión de niveles. La política es de alto nivel; los pasos van en el procedimiento.
"Elijo un solo marco y descarto el resto"	Los marcos se combinan. Usa CSF/ISO como estructura y CIS/800-53 para controles concretos.
"Cumpla el marco, luego cumpla la ley"	Marco ≠ regulación. Mapea explícitamente cada obligación legal; un marco no garantiza cumplimiento.
"Reporto solo KPIs"	Los KPIs miran atrás. Añade KRIs para anticipar riesgo antes de que se materialice.
"Nadie aprueba ni revisa las políticas"	Sin dueño ni cadencia, la política queda obsoleta. Asigna aprobador y revisión anual.
"Mido madurez por número de controles"	La madurez es repetibilidad y medición del proceso, no cantidad de controles.

Preguntas frecuentes

 **¿Cuál es la diferencia entre gobierno y gestión?** El gobierno fija la dirección, el apetito de riesgo y la rendición de cuentas (nivel junta/CISO); la gestión ejecuta esa dirección con procesos y controles. Gobierno decide *qué y por qué*; gestión, *cómo*.

 **¿ISO 27001 o NIST CSF?** ISO 27001 es certificable y orientado a un SGSI auditable por terceros; NIST CSF 2.0 es flexible y basado en resultados/funciones. Muchas organizaciones usan CSF para comunicar postura y 27001/800-53 para el detalle de controles.

 **¿Qué es más importante, cumplir la regulación o reducir riesgo?** Ambos, pero no son lo mismo: el cumplimiento es un piso mínimo obligatorio; la gestión de riesgo puede exigir más. Un programa maduro cumple la ley y trata el riesgo residual según su apetito.

 **¿Cada cuánto se revisan las políticas?** Al menos anualmente y ante cambios significativos (nueva regulación, incidente mayor, cambio de negocio). Cada política debe declarar su cadencia y su aprobador.

Referencias

- Chapple, Stewart & Gibson. *(ISC)² CISSP Official Study Guide*, 9.^a ed., Sybex — Dominio 1.
- NIST. *Cybersecurity Framework (CSF) 2.0* — nist.gov/cyberframework.
- ISO/IEC 27001:2022 — *Information security management systems*.
- NIST. *Security and Privacy Controls* — [SP 800-53 Rev.5](#).
- CIS Controls v8 — cisecurity.org/controls.



Material descargable

-  [Guía en PDF](#) — versión imprimible de esta clase.
-  [Presentación \(PPTX\)](#) — deck para proyectar en clase.



Clase anterior

[Clase 319 — Análisis avanzado de phishing y correo malicioso](#)



Siguiente clase

[Clase 321 — Comunicación y reporte para analistas de seguridad](#)